

Audit de sécurité informatique

Table de matières :

Introduction.....	3
I - Points abordés lors de cet audit de sécurité informatique.....	3
II – Vérification des points abordés.....	4
II/I - L'enregistrement des authentifications au serveur sur des journaux (logs).....	4
II/II – Configuration du pare-feu.....	4
II/III – Gestion des connexions potentiellement dangereuses.....	4
II/IV – Gestion des comptes utilisateurs et admins.....	8
II/V – Politique des sauvegardes.....	8
II/VI – Politique des mots de passe.....	8
Problématique.....	8
Solution.....	9
Politique des mots de passe.....	9
II/VII – Quelques vulnérabilités possibles.....	11
Introduction :.....	11
Breach attack.....	11
Clickjacking.....	11
Strict-Transport-Security HTTP.....	11
MIME attack.....	11
Version de nginx.....	12

Introduction

Les systèmes d'information d'une entreprise doivent être faits afin de respecter les quatre principes fondamentaux de la sécurité des systèmes d'information :

- La confidentialité vise à assurer que les données ne sont accessibles qu'aux seules personnes autorisées.
- La disponibilité doit rendre les données accessibles et utilisables par les personnes autorisées sans interruption.
- L'intégrité s'assure que les données ne peuvent pas être modifiées pendant leur transfert, leur traitement ou leur stockage.
- La preuve consiste à apporter la preuve non réfutable d'un acte malveillant.

I - Points abordés lors de cet audit de sécurité informatique

Pour cet audit, on va s'intéresser à plusieurs points clés qui doivent être maîtrisés au maximum pour garantir la sécurité du système de l'entreprise :

- L'enregistrement des authentifications au serveur sur des journaux (logs)
- Configuration du pare-feu (firewall)
- Gestion des connexions potentiellement dangereuses
- Gestion des comptes utilisateurs et admins
- Politique des sauvegardes
- Politique des mots de passe
- Vulnérabilités

II – Vérification des points abordés

II/I - L'enregistrement des authentifications au serveur sur des journaux (logs)

Toutes les authentifications doivent être enregistrées sur des logs pour en garder en trace et l'utiliser comme preuve en cas de piratage ou autre. Cela est très important car sans les journaux il n'y a pas de preuve.

Pour le service SSH je vois que les authentifications et les essais d'authentification sont enregistrées sur le répertoire `/var/log/auth.log`.

Le `mail.log` se retrouve vide et n'a pas été modifié depuis le 22 juin. Ainsi tous les `procmail.log` sont vides, même ceux qui sont sauvegardés et compressés.

Le `ufw.log` est aussi vide et n'a pas été modifié depuis 1 semaine.

Pour le service ftp, les logs sont bien enregistrés et sauvegardés (en compression) sur un dossier `proftpd`.

II/II – Configuration du pare-feu

Le pare-feu est un système de sécurité de réseau informatique qui limite le trafic Internet entrant, sortant ou à l'intérieur d'un réseau privé.

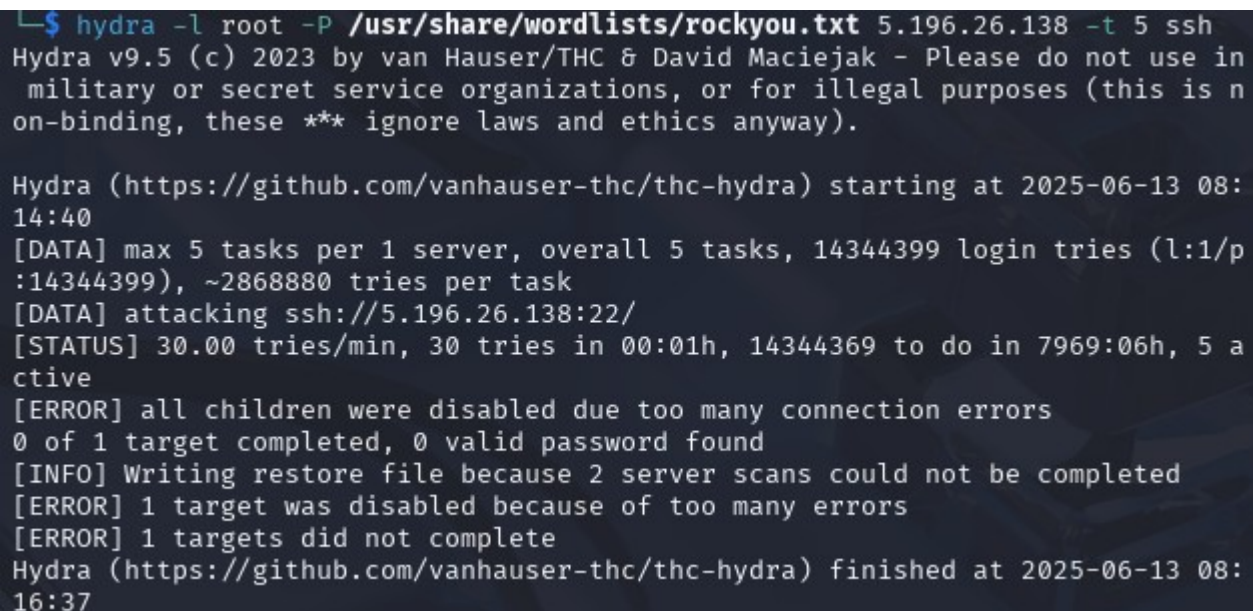
En ce moment le VPS Yorsil permet l'accès à tout le monde en ssh et ftp par exemple. Peut-être il faudrait permettre ces accès seulement à certaines IP, comme par exemple celles des développeurs ou celle de l'entreprise Yorsil.

II/III – Gestion des connexions potentiellement dangereuses

Dans cette partie on va essayer de se connecter à différents services sur le serveur en tant que personne non autorisée. Pour cela on va utiliser l'outil « hydra ».

Service SSH :

Je vais essayer de me connecter sur SSH au serveur en utilisant une bibliothèque avec 14 millions de mots de passe :

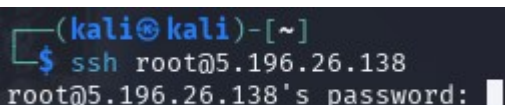


```
$ hydra -l root -P /usr/share/wordlists/rockyou.txt 5.196.26.138 -t 5 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-13 08:
14:40
[DATA] max 5 tasks per 1 server, overall 5 tasks, 14344399 login tries (l:1/p
:14344399), ~2868880 tries per task
[DATA] attacking ssh://5.196.26.138:22/
[STATUS] 30.00 tries/min, 30 tries in 00:01h, 14344369 to do in 7969:06h, 5 a
ctive
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-13 08:
16:37
```

Comme on voit sur l'image, on n'a pu faire que 30 essais avant que la connexion en SSH soit arrêtée. Cela est très positif car on bloque l'attaquant avant qu'il fasse beaucoup d'essais. Un autre point positif est qu'après trois essais, le serveur nous bloque automatiquement.

Dans un premier temps cela semble positif, mais lorsqu'on essaie de se connecter normalement, on voit que c'est encore possible même après avoir fait l'attaque :



```
(kali@kali)-[~]
$ ssh root@5.196.26.138
root@5.196.26.138's password: █
```

La connexion SSH est celle qui est le plus souvent attaquée par les personnes malveillantes, c'est pour cela que c'est très important de le sécuriser au maximum.

L'utilisation de "Fail2ban" permet de garantir le bannissement des individus qui ne respectent pas les règles que l'on a défini auparavant.

Ce programme va créer dynamiquement créer des règles au niveau du pare-feu pour bloquer certaines adresses IP.

Dans le cas de Yorsil, je me rends au fichier de configuration de Fail2ban situé dans le répertoire "/etc/fail2ban/jail.local".

Sur ce fichier je retrouve que ssh a été configuré ainsi:

```
[sshd]
```

```
enabled = true
```

Cela est négatif car même s'il a été activé, il y a aucune configuration qui la complète. Dans ce cas un attaquant est forcé à une déconnexion après 3 essais, mais il ne va être banni ni bloqué pour aucune période de temps.

Un exemple de configuration est:

```
[sshd]
```

```
enabled = true
```

```
filter = sshd
```

```
logpath = /var/log/auth.log
```

```
maxretry = 3
```

```
bantime = 3600
```

```
findtime = 3000
```

Sur FTP :

Pour me connecter sur FTP je vais utiliser la même bibliothèque qu'avec SSH :

```
(kali@kali)-[~]
$ hydra -l root -P /usr/share/wordlists/rockyou.txt 5.196.26.138 -t 5 ftp
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-13 09:
52:18
[DATA] max 5 tasks per 1 server, overall 5 tasks, 14344399 login tries (l:1/p
:14344399), ~2868880 tries per task
[DATA] attacking ftp://5.196.26.138:21/
[STATUS] 673.00 tries/min, 673 tries in 00:01h, 14343726 to do in 355:14h, 5
active
[STATUS] 675.67 tries/min, 2027 tries in 00:03h, 14342372 to do in 353:47h, 5
active
[STATUS] 680.43 tries/min, 4763 tries in 00:07h, 14339636 to do in 351:15h, 5
active
[STATUS] 680.93 tries/min, 10214 tries in 00:15h, 14334185 to do in 350:51h,
5 active
[STATUS] 680.52 tries/min, 21096 tries in 00:31h, 14323303 to do in 350:48h,
5 active
[STATUS] 679.79 tries/min, 31950 tries in 00:47h, 14312449 to do in 350:55h,
5 active
[STATUS] 680.25 tries/min, 42856 tries in 01:03h, 14301543 to do in 350:24h,
5 active
[STATUS] 667.84 tries/min, 52759 tries in 01:19h, 14291640 to do in 356:40h,
5 active
```

Comme on peut le voir il y a rien qui bloque les essais de connexions ce qui peut à un moment donné, permettre à l'attaquant de récupérer le mot de passe d'un compte utilisateur ou admin.

J'ai sorti cet extrait du log de ftp sur lequel on voit que quelqu'un est entrain d'essayer de se connecter au VPS via ftp pour récupérer les données dans le VPS. Cela est un petit extrait des essais qu'il a fait en moins d'une seconde avec un programme.

```
proftpd[237904] 0.0.0.0 (8.218.234.50[8.218.234.50]): USER test: no such user found from 8.218.234.50 [8.218.234.50]
proftpd[237904] 0.0.0.0 (8.218.234.50[8.218.234.50]): USER test: no such user found from 8.218.234.50 [8.218.234.50]
proftpd[237904] 0.0.0.0 (8.218.234.50[8.218.234.50]): USER test: no such user found from 8.218.234.50 [8.218.234.50]
proftpd[237907] 0.0.0.0 (8.218.234.50[8.218.234.50]): USER dev: no such user found from 8.218.234.50 [8.218.234.50]
proftpd[237907] 0.0.0.0 (8.218.234.50[8.218.234.50]): USER dev: no such user found from 8.218.234.50 [8.218.234.50]
proftpd[237907] 0.0.0.0 (8.218.234.50[8.218.234.50]): USER dev: no such user found from 8.218.234.50 [8.218.234.50]
```

Pour la configuration de ftp sur fail2ban peut être améliorée avec par exemple :

```
[proftpd]
enabled = true
filter = proftpd
logpath = /var/log/proftpd/proftpd.log
backend = auto
action = iptables[name=PROFTPD, port=ftp, protocol=tcp]
maxretry = 5
bantime = 3600
findtime = 600
```

Sur DOVECOT et POSTFIX :

Dovecot et postfix sont les deux composants qui permettent le fonctionnement de la messagerie mail utilisée. Comme pour ssh, on va utiliser fail2ban pour le protéger un minimum.

En ce moment, la configuration de ces deux éléments n'est pas mauvaise mais ce sera bien de la compléter. Par exemple:

[dovecot]

enabled = true

filter = dovecot

logpath = /var/log/mail.log

maxretry = 3

bantime = 600

findtime = 600

[postfix]

enabled = true

filter = postfix

logpath = /var/log/mail.log

maxretry = 3

bantime = 600

findtime = 600

[postfix-sasl]

enabled = true

backend = auto

filter = postfix[mode=auth]

logpath = /var/log/mail.log

maxretry = 3

bantime = 600

findtime = 600

Sur WEBMIN :

Pour ce service il faut trouver une bonne configuration pour le protéger au maximum, comme sur les exemples précédents.

Ces configurations peuvent être encore améliorées mais c'est une base sur laquelle il faut travailler.

Sur toutes les configurations mentionnées en haut, elles doivent être modifiées selon plusieurs choses, par exemple pour les mails, vu que le mail.log n'enregistre aucune information (peut être celui qui a configuré le serveur a changé l'emplacement). Ainsi par exemple il peut y avoir des ports personnalisés qui doivent être précisés sur la config.

C'est même possible et de mettre en place du GeoIPBan pour bloquer les connexions au VPS depuis certains pays. Par exemple une connexion de Chine sera bloquée automatiquement.

On peut aussi modifier les ports de connexion (ssh, ftp...).

C'est possible de faire une whitelist pour les utilisateurs qui pourront avoir accès au VPS via SSH.

Pour s'authentifier on peut utiliser différents moyens et interdire l'authentification par mot de passe. Par exemple le TOTP (Time-Based One-Time Passwords) ou l'accès à partir d'une paire de clés.

Il y a des scripts qui permettent de faire des audits au niveau de l'accès et la configuration SSH (jtesta?).

Les services qui en sont pas utilisés doivent être désactivés.

[What is an Intrusion Prevention System? - Palo Alto Networks](#)

II/IV – Gestion des comptes utilisateurs et admins

Tout d'abord il faut interdire l'accès par SSH au serveur depuis le compte root. Le compte root est celui qui est attaqué en premier par les hackers car c'est celui qui est souvent utilisé sur les serveurs.

[Linux OpenSSH server deny root user access / log in - nixCraft](#)

Il faut ainsi désactiver l'accès root par ftp :

```
2025-07-02 14:21:19,237 vps-0a0efc28.vps.ovh.net proftpd[2136465] 0.0.0.0 (101.126.133.86[101.126.133.86]): USER root (Login failed): Incorrect password
2025-07-02 14:21:23,084 vps-0a0efc28.vps.ovh.net proftpd[2136470] 0.0.0.0 (101.126.133.86[101.126.133.86]): USER root (Login failed): Incorrect password
2025-07-02 14:21:26,843 vps-0a0efc28.vps.ovh.net proftpd[2136476] 0.0.0.0 (101.126.133.86[101.126.133.86]): USER root (Login failed): Incorrect password
2025-07-02 14:21:30,409 vps-0a0efc28.vps.ovh.net proftpd[2136477] 0.0.0.0 (101.126.133.86[101.126.133.86]): USER root (Login failed): Incorrect password
2025-07-02 14:21:34,107 vps-0a0efc28.vps.ovh.net proftpd[2136503] 0.0.0.0 (101.126.133.86[101.126.133.86]): USER root (Login failed): Incorrect password
```

[Ftp Disable RootLogin - QNAPedia](#)

Il ne faut pas oublier qu'avant de désactiver l'utilisateur root, il faut avoir un autre utilisateur avec les mêmes droits d'accès et privilèges pour éviter de se retrouver bloqués et sans accès au VPS. Tout de même il faut mettre en place un mot de passe fort pour le compte root même s'il ne va pas être utilisé.

Tous les comptes qui ne sont plus en utilisation doivent être désactivés ou supprimés.

II/V – Politique des sauvegardes

Une politique de sauvegardes est très important pour garder une traçabilité sur le VPS.

Je vais m'intéresser aux logs mais les sauvegardes peuvent être faites sur différents éléments d'un serveur :

- Tout d'abord il faut enregistrer les logs chaque jour à minuit et les compresser si possible.
- Si possible enregistrer une copie sur un autre support.

Par l'instant, j'ai vu ces sauvegardes pour le ftp.

II/VI – Politique des mots de passe

Problématique

Lorsqu'on se connecte souvent au même service, on a tendance d'utiliser un mot de passe simple facile à mémoriser. Dans le cas d'un compte admin cela est un risque très important.

Si un compte admin a un mot de passe simple, un hacker qui connaît l'identifiant peut faire une attaque brute-force et accéder facilement au compte.

En utilisant le site Bitwarden je teste ce mot de passe « Younes84 » :

Evaluate your password:

Younes84

Your password strength:

weak

Estimated time to crack:

17 minutes

En seulement 17 minutes ce mot de passe peut être trouvé par une personne malveillante.

Un autre problème avec les mots de passe est la façon de les enregistrer. Souvent, on écrit les mots de passe sur des fichiers de texte sur notre ordinateur ou sur un bout de papier qu'on laisse toujours sur notre ordinateur. Cela est dangereux car en cas de vol de l'ordinateur ou l'intrusion d'une personne malveillante sur notre ordinateur. On peut exposer l'ensemble de nos mots de passe.

Solution

Politique des mots de passe

L'ANSSI propose différents moyens pour obtenir une authentification forte :

R1	Utilisez des mots de passe différents pour vous authentifier auprès de systèmes distincts. En particulier, l'utilisation d'un même mot de passe pour sa messagerie professionnelle et pour sa messagerie personnelle est à changer impérativement.
R2	Choisissez un mot de passe qui n'est pas lié à votre identité (mot de passe composé d'un nom de société, d'une date de naissance, etc.)
R3	Ne demandez jamais à un tiers de créer pour vous un mot de passe.
R4	Modifiez systématiquement et au plus tôt les mots de passe par défaut lorsque les systèmes en contiennent.
R5	Renouvelez vos mots de passe avec une fréquence raisonnable. Tous les 90 jours est un bon compromis pour les systèmes contenant des données sensibles.
R6	Ne stockez pas les mots de passe dans un fichier sur un poste informatique particulièrement exposé au risque (exemple : en ligne sur internet), encore moins sur un papier facilement accessible.
R7	Ne vous envoyez pas vos propres mots de passe sur votre messagerie personnelle.
R8	Configurez les logiciels, y compris votre navigateur web, pour qu'ils ne se « souviennent » pas des mots de passe choisis.

Ils conseillent d'utiliser un mot de passe d'au moins 12 caractères, idéalement un passphrase (passe de phrase ou phrase secrète). Pour cela deux méthodes :

- La méthode phonétique : « J'ai acheté huit CD pour cent euros cet après-midi » deviendra : gAht8CDé%€sE7aM.

Evaluate your password:

gAht8CDé%€sE7aM

Your password strength:
strong

Estimated time to crack:
centuries

- La méthode des premières lettres : la citation « un tient vaut mieux que deux tu l'auras » donnera : 1t-Vm*Q2tUl'A.

Evaluate your password:

1t-Vm*Q2tUl'A

Your password strength:
strong

Estimated time to crack:
31 years

Gestion des mots de passe

Pour bien gérer ses mots de passe il faut utiliser un gestionnaire de mots de passe comme keepass.

Changer les mots de passe chaque 90 jours à peu près pour les comptes qui donnent accès à des données sensibles.

II/VII – Quelques vulnérabilités possibles

Introduction :

L'objectif de cette partie est de trouver des vulnérabilités concernant le site web, pour cela j'ai utilisé plusieurs outils :

- Nikto
- Dir
- Dirb
- Hydra
- Zenmap

Breach attack

L'attaque BREACH est une vulnérabilité qui exploite la compression HTTP (notamment gzip ou deflate) pour extraire des informations sensibles du trafic web chiffré. Les attaquants peuvent ainsi récupérer des jetons de connexion, des adresses e-mail, et d'autres données confidentielles.

En utilisant l'outil « Nikto » j'ai pu récupérer cet avertissement « The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack ».

[BREACH attacks: What are they and how to prevent them](#)

Clickjacking

En utilisant l'outil « Nikto » j'ai pu récupérer cet avertissement « The anti-clickjacking X-Frame-Options header is not present ». Le clickjacking consiste à exploiter l'interface utilisateur pour piéger les victimes en les poussant à interagir avec des éléments invisibles ou déguisés.

Exemple : [Clickjacking - Security | MDN](#)

Strict-Transport-Security HTTP

En utilisant l'outil « Nikto » j'ai pu récupérer cet avertissement « The site uses TLS and the Strict-Transport-Security HTTP header is not defined ». Cet option permet d'obliger le navigateur d'utiliser HTTPS même si la demande se fait en HTTP. Je me suis rendu compte que même si j'essaie de me connecter en HTTP, ça me renvoie automatiquement en HTTPS. Mais ça pourrait être bien de l'ajouter si ce n'est pas encore fait.

MIME attack

En utilisant l'outil « Nikto » j'ai pu récupérer cet avertissement « The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type ». La MIME attack consiste à cacher un fichier HTML en tant qu'un jpg ou autre type de fichier. Cela peut arriver dans les sites web qui permettent aux utilisateurs charger des fichiers sur le serveur.

[Missing Content-Type Header Detected on Web Application | Invicti](#)

[What Is MIME Sniffing? - KeyCDN Support](#)

Version de nginx

La version de nginx est la 1.18.0 alors qu'il y a déjà des versions supérieures. Cela peut être source de risques car les vulnérabilités des versions précédentes et qui ne sont plus mises à jour peuvent faire face à des importantes vulnérabilités.

Dans le cas du VPS Yorsil, je vois qu'en réalité c'est la version 20.04.6 LTS (Long Term Support). Les versions LTS d'Ubuntu sont supportées pour 5 ans (chaque avril), cette version correspond à avril 2020. Donc le support de cette version est finie avril 2025. Il faut donc rapidement mettre le système d'exploitation à jour.

Pour le faire on peut utiliser la commande **do-release-upgrade**.

Cela met à jour la version de 20.04 à 22.04.

Ainsi il y a plusieurs modules et programmes qui peuvent être mis à jour.

[How to Hide Nginx Server Version in Linux](#)

Il y a des Intrusion Detection System (IDS) qui font des scans automatiquement.

Sous ubuntu, il est très simple de mettre à jour ses paquets avec le gestionnaire APT et de les installer ensuite :

```
apt-get update
```

Puis

```
apt-get upgrade
```